

OSFI GUIDELINE B-13 -- TECHNOLOGY AND CYBER RISK MANAGEMENT

Gap Assessment Executive Summary

Prepared for the Board of Directors and Executive Leadership

Lakeview Trust Corporation

Toronto, Ontario | Federally Regulated Trust Company | OSFI Regulated

Document ID: LT-B13-003 | Version 1.0 | Date: [Insert Date]

Prepared by: [Your Name] | Classification: Confidential

DOCUMENT CONTROL	
Document Title	OSFI B-13 Gap Assessment -- Executive Summary Report
Document ID	LT-B13-003
Version	1.0
Date	05/20/2026
Prepared By	Ashkon Irani
Reviewed By	Chief Risk Officer
Presented To	Board of Directors and Executive Leadership Team
Classification	Confidential
Regulatory Reference	OSFI Guideline B-13 -- Technology and Cyber Risk Management (Effective January 1, 2024)
Related Documents	LT-B13-001 Company Profile and Assessment Scope, LT-B13-002 Gap Analysis Spreadsheet

1. Purpose and Audience

This executive summary presents the findings of Lakeview Trust Corporation's assessment of compliance with OSFI Guideline B-13 -- Technology and Cyber Risk Management. It is written for the Board of Directors and executive leadership team and is intentionally free of technical language. Its purpose is to give the board an accurate picture of where Lakeview Trust currently stands against B-13, what the most serious gaps are, and what actions leadership must take to address them.

This document summarizes findings from the Gap Analysis Spreadsheet (LT-B13-002), which contains detailed requirement-by-requirement assessments across all five B-13 domains. The full Gap Analysis should be reviewed by the Chief Risk Officer and Chief Information Security Officer. This summary is the board-level read.

B-13 is not a voluntary standard. It is an OSFI regulatory expectation effective January 1, 2024. Material gaps identified in this assessment, if unaddressed, are likely to generate supervisory findings at Lakeview Trust's next OSFI examination. The board must be aware of the current compliance position and must approve a remediation plan.

2. What B-13 Requires and Why It Matters

OSFI Guideline B-13 sets out expectations for how federally regulated financial institutions manage technology and cyber risk. It covers five domains: governance and risk management, technology operations and resilience, cyber security, third-party and technology service provider risk, and technology innovation.

B-13 came into full effect on January 1, 2024, replacing the older B-10 outsourcing guideline with a significantly broader and more demanding framework. OSFI issued B-13 in direct response to the increasing frequency and severity of technology failures and cyber incidents at financial institutions globally, and in recognition that technology risk is now one of the most significant risks facing the Canadian financial sector.

The consequences of material non-compliance with B-13 are real and escalating. OSFI's supervisory process begins with observations and management letters but can escalate to formal supervisory directions, restrictions on business activities, and in extreme cases appointment of an administrator. Beyond regulatory consequences, a significant technology failure or cyber breach at a trust company handling personal client assets and registered investment accounts carries severe reputational consequences that can be difficult to recover from.

3. Overall Compliance Position

Lakeview Trust's overall B-13 maturity was assessed at Level 2 out of 5 -- Developing. This means that some practices exist across the five domains, but they are largely undocumented, inconsistently applied, or lack the governance oversight that B-13 requires. This is a common finding for institutions of Lakeview Trust's size and profile at the outset of a formal B-13 compliance program, but it represents a significant gap relative to OSFI's expectations that requires urgent and sustained remediation.

Domain	Maturity Score	Requirements Assessed	Critical / High Gaps	Status
Governance and Risk Management	2 -- Developing	7	3	Remediation required
Technology Operations and Resilience	2 -- Developing	7	2	Remediation required

Cyber Security	2 -- Developing	10	5	Remediation required
Third-Party and Technology Service Provider Risk	1 -- Initial	6	4	Immediate action
Technology Innovation	2 -- Developing	4	2	Remediation required

Of 34 requirements assessed, 8 are rated Critical, 8 are rated High, 13 are rated Medium, and 5 are rated Low. The 16 Critical and High gaps represent the most urgent priorities and are the focus of the recommended actions in Section 6 of this report.

4. Domain-by-Domain Summary

Domain 1 -- Governance and Risk Management | Maturity: 2 -- Developing

Governance is the foundation of B-13 compliance. Without board-approved risk appetite for technology and cyber risk, clearly defined senior management accountability, and effective three-lines-of-defense oversight, the controls implemented in other domains lack the governance structure needed for OSFI to regard them as credible.

Lakeview Trust's most significant governance gaps are the absence of a board-approved technology and cyber risk appetite statement, the lack of a Chief Information Security Officer role, and the limited integration of technology risk into the enterprise risk management framework. These are not technical deficiencies -- they are leadership and governance decisions that require board action to resolve.

The absence of a board-approved technology risk appetite is the single most foundational gap in this assessment. OSFI will look for this at the next examination. It must be resolved before any other governance improvements can be considered effective.

Domain 2 -- Technology Operations and Resilience | Maturity: 2 -- Developing

Lakeview Trust has basic technology operations processes in place, but several significant gaps threaten the organization's ability to maintain reliable service delivery and recover disruptions. The most critical finding is that the disaster recovery documentation for core banking and fiduciary systems has not been updated following the Azure migration completed 18 months ago. This means that if Lakeview Trust needed to invoke its DR plan today, the procedures may not accurately reflect how recovery would be executed.

Two servers in the Toronto data center are running operating systems that reached end of support eight months ago, meaning they no longer receive security patches. This represents a persistent and unmitigable vulnerability in the environment hosting the most sensitive client data.

Domain 3 -- Cyber Security | Maturity: 2 -- Developing

Cyber security is the domain with the highest number of Critical gaps. Lakeview Trust does not have MFA enforced for internal Microsoft 365 access or administrative access to the Azure environment, meaning that a single stolen password is sufficient for an attacker to gain access to internal communications and cloud

infrastructure. The last external penetration test was conducted 27 months ago with two High findings still unresolved.

There is no formal cyber security program with a board-endorsed mandate. Security activities are largely reactive. The security monitoring capability, while partially deployed through Azure Sentinel, does not cover the on-premises core banking and fiduciary systems that hold the most sensitive client data.

The MFA gap is the highest priority technical finding in this assessment. An attacker who obtains one employee's Microsoft 365 password currently has unrestricted access to that employee's email, documents, and calendar with no additional barrier. This must be resolved within 30 days.

Domain 4 -- Third-Party and Technology Service Provider Risk | Maturity: 1 -- Initial

Third-party risk management is the lowest-scoring domain in this assessment. Lakeview Trust has no formal vendor risk management program, no standardized security assessment process for technology vendors, and critically, no security clauses in several major vendor contracts including the FIS mortgage platform contract executed in 2019. This means that if FIS experienced a data breach affecting Lakeview Trust client data today, Lakeview Trust would have no contractual right to notification, no right to audit, and no contractual obligation on FIS to remediate.

Given the reliance on FIS for mortgage origination and servicing, and on the fiduciary management system for estate and trust administration, the absence of vendor risk management controls represents a concentration of unmanaged risk that OSFI would view as a material gap.

Domain 5 -- Technology Innovation | Maturity: 2 -- Developing

Technology innovation risk is an emerging focus area for OSFI and one where many institutions are still building their programs. Lakeview Trust's most significant gap is the absence of formal governance over AI risk. The credit scoring model used for mortgage underwriting decisions has been in place for six years without a formal risk assessment covering model bias, explainability, or performance validation. This creates regulatory risk not only under B-13 but potentially under FCAC fair lending expectations.

The planned core banking modernization in the three-year strategic plan proceeds without formal technology risk assessment requirements embedded in the project approval process, which is a governance gap that could result in significant unmanaged risk if not addressed before the project commences.

5. The Ten Most Critical Findings

The following ten findings represent the highest-priority gaps identified across the assessment. Each is rated Critical or High severity and requires a funded remediation plan with named executive ownership before the next OSFI examination.

#	Ref	Finding	Why It Matters	Required Action
1	D3-02	No MFA on internal Microsoft 365 and Azure admin accounts	A stolen password gives an attacker unrestricted access to internal systems with no second barrier. The most common attack vector against	Enforce MFA for all Microsoft 365 accounts within 30 days via Conditional Access. Implement phishing-

			financial institutions today is the case.	resistant MFA for Azure admin access.
2	D1-01	No board-approved technology and cyber risk appetite	Without a formal risk appetite, the board cannot exercise meaningful oversight of technology risk. OSFI will look for this at the next examination.	Develop and present a technology and cyber risk appetite statement to the board of Risk Committee within 60 days.
3	D2-03	Disaster recovery plans not updated after Azure migration	DR procedures referencing pre-migration architecture may not work when invoked. An untested, outdated DR plan provides false confidence in recovery capability.	Update all DR documentation immediately. Conduct a full DR test within 90 days. Report results to the board of Risk Committee.
4	D4-01	No formal third-party technology risk management program	Lakeview Trust has no visibility in the security posture of vendors supporting critical systems. A vendor's breach could expose client data with no contractual recourse.	Implement a vendor risk program with tier classification, security questionnaires, and mandatory security clauses for all Critical and High tier vendors within 90 days.
5	D3-03	Critical vulnerabilities open for an average of 47 days	Vulnerabilities that remain unpatched for weeks provide sustained opportunity for exploitation. This is an active, ongoing risk, not a theoretical one.	Define and enforce remediation of SLAs immediately. Critical vulnerabilities within 48 hours. Report compliance weekly to the CIO.
6	D4-03	No security clauses in FIS and other major vendor contracts	No contractual right to notification, audit, or remediation if a critical vendor is breached. FIS processes client financial data for all mortgage customers.	Prioritize FIS contract amendment to include security requirements, incident notification within 24 hours, and audit rights within 60 days.
7	D3-07	Penetration test 27 months old with two High findings unresolved	Lakeview Trust's last external assessment is significantly out of date and left known vulnerabilities unresolved. OSFI expects annual testing of critical systems.	Commission for an immediate penetration test. Resolve all open findings before the new test begins. Establish annual testing as a mandatory calendar event.
8	D3-01	No formal board-endorsed cyber security program	Reactive, ad hoc security activities without a formal program and board mandate cannot demonstrate to OSFI that cyber risk is being managed systematically.	Develop a cyber security program charter aligned to NIST CSF 2.0. Obtain board Risk Committee approval within 90 days.

9	D2-06	Two servers running unsupported operating systems	End-of-life systems no longer receive security patches. Vulnerabilities in these systems cannot be remediated, creating persistent unmanaged risk in the data center.	Upgrade or isolate end-of-life systems within 90 days. Establish a lifecycle management policy preventing future end-of-life situations.
10	D5-02	No formal AI risk assessment for credit scoring model	An AI model influencing mortgage lending decisions without bias testing, explainability documentation, or performance validation creates regulatory risk under both B-13 and FCAC fair lending expectations.	Commission for a formal AI risk assessment of the credit scoring model within 90 days. Develop an AI governance policy covering all AI system use.

6. Recommended Board Actions

The following actions require decisions or endorsement at the board or CEO level. They cannot be resolved by the technology team alone. Items 1 through 4 are urgent and should be taken at the next board or Risk Committee meeting.

#	Action Required	Why Board Involvement Is Required	Recommended Timeline
1	Approve the technology and cyber risk appetite statement	Risk appetite is a board governance decision. The board must formally define the level of technology and cyber risk Lakeview Trust is willing to accept. This cannot be delegated to management.	Present at the next board Risk Committee meeting. Target approval within 60 days.
2	Direct management to commission an immediate penetration test and DR test	Both tests involve expenditure and cross-functional disruption that requires board and CEO endorsement to prioritize above competing demands.	Formal direction at the next board meeting. Both tests commence within 30 days of direction.
3	Approve the establishment of a CISO role or formal cyber security accountability mandate	Accountability for cyber security risk management must be formally established at the senior management level. This is a governance and resourcing decision requiring board awareness.	CEO to present the proposed accountability model to the board within 60 days.
4	Approve a B-13 remediation plan and budget	Closing the gaps identified in this assessment requires investment. The board must approve the remediation plan and ensure adequate resources are allocated. A remediation	The CEO and CRO present a cost remediation plan to the board within 90 days.

		plan without a budget is not a plan.	
5	Receive quarterly B-13 remediation progress reports	The board is accountable to OSFI for the institution's compliance posture. Regular reporting is required for meaningful oversight and to demonstrate to OSFI that the board is engaged.	Quarterly reporting to board the Risk Committee beginning immediately. First report at the next scheduled meeting.
6	Endorse mandatory security clauses for all future technology vendor contracts	Contractual security requirements cannot be added to existing contracts without negotiation but can be mandated for all new and renewing contracts by board policy.	Board to endorse vendor contract security standards as board policy at next meeting.

7. Remediation Roadmap

The following roadmap sets out the recommended sequence of remediation activities over the next 12 months. It is prioritized by severity and regulatory risk, not by ease of implementation. Activities in the Immediate phase cannot be deferred.

Phase	Key Remediation Activities	Success Measure
Immediate (0 to 30 days)	Enforce MFA across all Microsoft 365 accounts. Update DR documentation to reflect post-migration architecture. Initiate penetration test procurement. Commence FIS contract amendment negotiation. Establish critical vulnerability remediation SLAs and begin clearing the backlog. Brief the board on assessment findings.	MFA at 100% coverage. DR documentation current. Pen test vendor engaged. FIS amendment in negotiation. Zero critical vulnerabilities older than 48 hours.
Short-term (30 to 90 days)	Conduct full DR test with documented results. Develop board-level technology risk appetite statements. Establish CISO accountability. Launch vendor risk program for Critical and High tier vendors. Deploy MFA for Azure administrative access. Develop cyber security program charter. Extend Sentinel SIEM to cover on-premises core banking logs.	DR test completed and results presented to board. Risk appetite approved. CISO mandate established. All Critical tier vendors assessed. SIEM covering all critical systems.
Medium-term (90 days to 6 months)	Complete penetration test and remediate all findings. Implement privileged access management for critical systems. Develop AI governance policy and conduct credit model risk assessment. Establish the technology adoption governance framework. Complete network segmentation review and remediation. Conduct first tabletop cyber incident response exercise.	All pen test findings are remediated. PAM deployed. AI risk assessment complete. Network architecture reviews are complete. Tabletop exercise conducted with senior management.

Ongoing (6 to 12 months)	Conduct full annual cycle of vendor security assessments. Implement quarterly phishing simulations. Establish board-level technology risk KRI dashboard. Conduct second penetration test cycle. Commission independent B-13 compliance review. Present 12-month remediation progress report to board.	All Tier 1 and 2 vendor assessments are complete. Phishing susceptibility rate tracked and declining. KRI dashboard live. Independent review commissioned. The Board receives comprehensive progress reports.
--------------------------	---	---

8. What Good Looks Like -- The 18-Month Target

Within 18 months of this assessment, Lakeview Trust should be in the following position. This is the target state the board should hold the CRO and CISO accountable for delivering.

- A board-approved technology and cyber risk appetite in place and actively monitored through a KRI dashboard reported to the board Risk Committee quarterly
- MFA enforced on 100 percent of accounts accessing Lakeview Trust systems including all internal, administrative, and remote access scenarios
- A tested and current disaster recovery capability for all critical systems with validated RTOs and RPOs reported to the board annually
- All Critical and High tier technology vendors operating under security-compliant contracts with annual security assessments completed
- A functioning SIEM providing 24/7 monitoring coverage of all critical systems including core banking and fiduciary platforms
- Annual penetration testing of all internet-facing systems and critical internal systems with all findings remediated within defined SLAs
- A formal AI governance policy in place with the credit scoring model validated for bias, explainability, and ongoing performance
- B-13 maturity scores at Level 3 or above across all five domains with a credible plan to reach Level 4 for governance and cyber security within 24 months

Reaching this target state will position Lakeview Trust as a B-13 compliant institution capable of demonstrating to OSFI that technology and cyber risk is managed with the rigor expected of a federally regulated trust company. It will also materially reduce the likelihood and impact of a technology failure or cyber incident affecting clients and the business.

9. Conclusion

Lakeview Trust faces a significant but manageable B-13 compliance gap. The findings in this assessment are consistent with what OSFI has observed across mid-tier trust companies and other federally regulated institutions in the first year of B-13's effectiveness. They do not reflect a failure of intent -- they reflect the reality that B-13 sets a higher bar than the previous regulatory framework, and most institutions are still working to reach it.

What distinguishes institutions that resolve these gaps quickly from those that struggle is board-level commitment and adequate resourcing. The technology and risk teams cannot close these gaps alone. The remediation program requires visible board endorsement, a funded plan, and named executive accountability.

With those three elements in place, Lakeview Trust can reach a strong B-13 compliance position within 18 months.

The CRO and CISO are available to present the detailed Gap Analysis findings and answer questions from the board at the next Risk Committee meeting.

10. Board Acknowledgement

By signing below, the board members confirm that they have reviewed this executive summary, that they understand the B-13 compliance position described, and that they are committed to directing management to implement the remediation actions recommended in Section 6.

Role	Name	Signature	Date
Prepared By	Ashkon Irani	[Signed]	05/20/2026
Reviewed By	Chief Risk Officer	[Signed]	05/20/2026
Reviewed By	Chief Information Security Officer	[Signed]	05/20/2026
Presented To and Acknowledged By	Chief Executive Officer	[Signed]	05/20/2026
Board Risk Committee Chair	David Marchetti	[Signed]	05/20/2026

-- End of Document --

LT-B13-003 v1.0 | Lakeview Trust Corporation | CONFIDENTIAL